RESUMEN — PRESENTACIÓN

Metodologías de Análisis y Evaluación de Riesgos en Ciberseguridad

Ciberseguridad CF2 · Gestión de la Seguridad de la Información

1. ¿Qué es el Análisis de Riesgos?

El análisis de riesgos es la consideración sistemática del daño probable que puede causar en el negocio un fallo en la seguridad de la información, con las consecuencias potenciales de pérdida de confidencialidad, integridad y disponibilidad. Constituye el primer punto de la gestión de la seguridad de la información de una organización.

De acuerdo con el estándar SP-830 del NIST, el proceso comprende la identificación de activos informáticos, sus vulnerabilidades y amenazas a los que se encuentran expuestos, así como su probabilidad de ocurrencia y el impacto de las mismas, a fin de determinar los controles adecuados para aceptar, disminuir, transferir o evitar la ocurrencia del riesgo.

1.1 Objetivos generales

- Planificación de la reducción de riesgos en los sistemas de información.
- Planificación de la prevención de accidentes e incidentes de seguridad.
- Visualización y detección de las debilidades existentes en los sistemas.
- Apoyo en la toma de las mejores decisiones en materia de seguridad de la información.

2. Metodologías de Análisis y Evaluación

Existen varias metodologías ampliamente adoptadas en el mundo empresarial para la gestión sistemática de riesgos en seguridad de la información. A continuación se sintetizan las cuatro estudiadas en esta presentación.

Metodología	Año/Origen	Enfoque principal	Herramienta clave
MAGERIT	España, 1997	Gestión de riesgos TI. 3 submodelos (elementos, eventos, procesos) + 3 volúmenes	Submodelo de elementos · Sector público
OCTAVE	CERT/CC · ISO 27001	Activos críticos operacionales. Divide activos en Sistemas y Personas	3 fases · Equipo multidisciplinar
CORAS	SINTEF · UE, 2001	Sistemas de seguridad críticos. Utiliza UML para modelar activos, amenazas y salvaguardas	7 pasos · Modelos UML · Biblioteca de casos

Metodología	Año/Origen	Enfoque principal	Herramienta clave
MEHARI	CLUSIF, 1998	Reducción y análisis de riesgos. BBDD de conocimiento para diagnóstico de medidas de seguridad	Cuestionarios CIA · Open source 2007

2.1 MAGERIT

MAGERIT (Metodología de Análisis y GEstión de Riesgos de los sistemas de Información de las Administraciones públicas) es una de las metodologías más utilizadas, especialmente en el ámbito hispanoparlante. Publicada por primera vez en 1997, se organiza en tres submodelos:

Submodelo de Elementos	Clasifica 6 elementos básicos: activos, amenazas, vulnerabilidades, impacto, riesgo y salvaguarda.
Submodelo de Eventos	Categoriza los elementos anteriores en tres formas: dinámico físico, dinámico organizativo y estático.
Submodelo de Procesos	Define 4 etapas: análisis de riesgo, planificación, gestión de riesgo y selección de salvaguardas.

2.2 OCTAVE

OCTAVE (Operationally Critical Threat, Asset and Vulnerability Evaluation) es un método de evaluación desarrollado con base en el estándar ISO 27001. Su núcleo es un conjunto de criterios principios, atributos y resultados que permiten desarrollar diversas metodologías. Divide los activos en dos tipos:

- Sistemas: hardware, software y datos.
- Personas: usuarios, administradores y personal de la organización.

El método propone tres fases: (1) perfil de amenazas de los activos, (2) identificación de vulnerabilidades de la infraestructura, y (3) desarrollo de la estrategia y del plan de seguridad.

2.3 CORAS

CORAS (Construct a Platform for Risk Analysis of Security Critical Systems) fue desarrollado a partir de 2001 por SINTEF, financiado por la Unión Europea. Proporciona un lenguaje gráfico basado en UML para la definición de modelos de activos, amenazas, riesgos y salvaguardas. Su proceso se estructura en 7 pasos:

- Paso 1 — Presentación: reunión inicial con objetivos y alcance del análisis.
- Paso 2 — Análisis de alto nivel: entrevistas y documentación de amenazas.
- Paso 3 — Aprobación: descripción detallada y aprobación del alcance.

- Paso 4 — Identificación de riesgos: amenazas, vulnerabilidades e incidentes.
- Paso 5 — Estimación de riesgo: probabilidades e impactos de los incidentes.
- Paso 6 — Evaluación de riesgo: informe de riesgos y correcciones.
- Paso 7 — Tratamiento del riesgo: salvaguardas y análisis coste/beneficio.

2.4 MEHARI

MEHARI (Méthode Harmonisée d'Analyse de Risques) fue desarrollada por CLUSIF en 1998 y se convirtió en open source en 2007. Su principal orientación es la evaluación y reducción de riesgos mediante bases de datos de conocimiento sobre amenazas, riesgos y vulnerabilidades. Sus tres fases fundamentales son:

Análisis de Riesgos	Evalúa factores estructurales y factores de reducción del riesgo mediante criterios cualitativos y cuantitativos.
Evaluaciones de Seguridad	Cuestionarios de controles para evaluar el nivel de calidad de los mecanismos de seguridad (servicios de seguridad).
Análisis de Amenazas	Escala de valores de malfuncionamientos y clasificación de activos TI por criterios CIA (Confidencialidad, Integridad, Disponibilidad).

3. Identificación y Evaluación de Amenazas

Una amenaza es la posibilidad de ocurrencia de cualquier tipo de evento o acción que puede producir un daño (material o inmaterial) sobre los elementos de un sistema. Conforme al estándar **SP-830**, se categorizan en tres tipos:

3.1 Amenazas Naturales

Amenaza	Descripción / Impacto	Nivel
Terremoto / Inundaciones	Destrucción física de la infraestructura TI. Afecta la disponibilidad total de los activos.	**ALTO**
Tormentas Eléctricas	Sobretensiones que dañan servidores, equipos activos y cableado estructurado.	**ALTO**
Vendavales / Huracanes	Interrupciones en la conectividad y daño a las instalaciones físicas del CPD.	**MEDIO**

3.2 Amenazas Humanas

Amenaza	Descripción / Impacto	Nivel
Acceso No Autorizado	Violación de confidencialidad e integridad mediante explotación de credenciales comprometidas.	**ALTO**
Malware / Phishing	Virus, ransomware e ingeniería social que comprometen datos críticos de la organización.	**ALTO**
Denegación de Servicio (DoS)	Imposibilita el acceso a los servicios, afectando la disponibilidad del sistema.	**ALTO**
Spoofing	Suplantación de identidad de usuarios o sistemas para obtener acceso no autorizado.	**ALTO**
Ingeniería Social	Manipulación psicológica del personal para obtener información confidencial.	**ALTO**

3.3 Amenazas de Entorno

Amenaza	Descripción / Impacto	Nivel
Fallas Eléctricas	Interrupciones de energía sin UPS ni generadores de respaldo. Impacto total en disponibilidad.	**ALTO**
Humedad / Polución	Corrosión de componentes en cuartos de telecomunicaciones sin control ambiental adecuado.	**MEDIO**
Incendios / Temperatura	Sin sistemas de detección y extinción automáticos, pérdida total de activos físicos y datos.	**ALTO**
Control de Acceso Físico	Ingreso no autorizado a salas de servidores y equipos de red de la organización.	**ALTO**

3.4 Valuación de Amenazas por Activo

A cada activo de la organización se le asigna un valor de amenaza como resultado de la suma ponderada de las amenazas naturales, humanas y de entorno identificadas. El ejemplo a continuación muestra los resultados para los activos más representativos:

Activo	A. Naturales	A. Humanas	A. Entorno	Valor Total
Servidor	1	5	3	**9**
Computador de escritorio	1	4	3	**8**
Impresora	1	1	2	**4**
Fotocopiadora	1	1	2	**4**

4. Determinación del Riesgo

El riesgo es el efecto negativo resultante cuando se produce un impacto sobre un activo, considerando tanto la probabilidad de la amenaza como el impacto de esta. La fórmula para su cálculo es:

RIESGO = Probabilidad de Amenaza × Impacto (Escala: Bajo=2 · Medio=3 · Alto=4)

Nivel de Riesgo	Valor	Criterio de Impacto
BAJO	6 – 9	Daño aislado. No perjudica ningún componente organizacional.
MEDIO	10 – 12	Desarticulación de un componente. Puede escalar si no se atiende.
ALTO	13 – 16	Desmoviliza o desarticula la organización en el corto plazo.

4.1 Estrategias de Tratamiento del Riesgo

Una vez calculado el riesgo, aquellos que superen el límite establecido deben ser tratados. Existen cuatro estrategias principales:

- Transferir: contratar un seguro o externalizar el riesgo a un tercero.
- Eliminar: remover el proceso o sistema sujeto a riesgo elevado.
- Asumir: aceptar el riesgo de forma justificada, cuando el coste del control supera el impacto.
- Mitigar: implementar medidas técnicas, físicas o administrativas para reducir el riesgo a niveles aceptables.

5. Controles de Seguridad

Los controles de seguridad son las medidas que la organización adopta para reducir el riesgo a niveles aceptables. Se clasifican en tres categorías:

Controles Fisicos	Controles Tecnicos	Controles Administrativos
• Camaras CCTV • Sistemas de alarma • Guardias de seguridad • Biometria • Puertas de acceso seguro	• Encriptacion • Tarjetas inteligentes • Autenticacion de red • Listas ACL • Auditoria de archivos	• Entrenamiento • Planes de recuperacion • Politicas de seguridad • Registro de personal • Separacion de funciones

6. Conclusión

La selección adecuada de una metodología de análisis de riesgos fortalece la toma de decisiones estratégicas en seguridad de la información. MAGERIT, OCTAVE, CORAS y MEHARI comparten

el objetivo de proteger los tres principios de la seguridad informática: Confidencialidad, Integridad y Disponibilidad (CIA).

El análisis sistemático de amenazas naturales, humanas y de entorno, vulnerabilidades e impactos permite a las organizaciones priorizar controles técnicos, físicos y administrativos acordes a su contexto y nivel de madurez. La documentación de resultados y el plan de tratamiento de riesgos constituyen insumos fundamentales para la gestión de la seguridad a largo plazo.

- La identificación de activos y su valuación de amenazas es el punto de partida del proceso.
- La probabilidad y el impacto determinan el nivel de riesgo sobre cada activo.
- El tratamiento del riesgo (transferir, eliminar, asumir o mitigar) cierra el ciclo de gestión.

7. Referencias Bibliográficas

Ministerio de Hacienda y Administraciones Publicas de Espana. (2012). MAGERIT v3 - Metodologia de Analisis y Gestion de Riesgos de los Sistemas de Informacion. PAe. https://administracionelectronica.gob.es/pae_Home/pae_Documentacion/pae_Metodolog/pae_Magerit.html

Alberts, C., & Dorofee, A. (2003). Introduction to the OCTAVE Approach. Carnegie Mellon University, CERT Program. https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=6583

Lund, M. S., Solhaug, B., & Stolen, K. (2011). Model-Driven Risk Analysis: The CORAS Approach. Springer. https://doi.org/10.1007/978-3-642-12323-8

CLUSIF. (2010). MEHARI 2010: Risk Analysis and Treatment Guide. Club de la Securite de l'Information Francais. https://clusif.fr/wp-content/uploads/2018/08/MeHARI-2010-Risk-Analysis-and-Treatment-Guide.pdf

National Institute of Standards and Technology. (2012). Guide for Conducting Risk Assessments (SP 800-30 Rev. 1). https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final